EC528

ZERO TRUST CONFINEMENT

DEMO 2 — OCT 21

Mentor: Charles Munson, MIT Lincoln Laboratory

Bharath Srividhya
Kimberly Wong
Mabelle Lambert
Mitchell Freitas
Youwei Chen

Confine the agent

nono: >..

Lock 1: nono confinement

The agent can write one request file to a write-only outbox. It cannot read the outbox, reach the network, call the executor, or access signing keys.

The watcher computes the request ID, digests, and policy version independently.

Authorize the action



Lock 2: EMILIA authorization

Two of three approvers sign a receipt for the exact action. The receipt binds the action and target, expires quickly, and can be used once.

A missing signature, changed action, expired receipt, or replay is denied.

Attest the node



Lock 3: Keylime attestation

The target must return a fresh Keylime PASS for the intended node. The workload and input bytes must match approved digests.

Execution uses verified file descriptors. Missing, stale, or failed attestation denies the request.

DEMO 2 GOALS

- Prove 2-of-3 approval for one exact action.
- Enroll a Keylime agent and protect bootstrap.
- Run the nono-confined agent end to end.
- Measure what fails closed and identify what remains for Demo 3.



REQUEST PATH

The confined agent writes one request file. The watcher recomputes IDs and digests. EMILIA grants an exact-action 2-of-3 receipt. The dispatcher consumes it once over an SSM tunnel.

EXECUTION PATH

On AWS, Keylime checks the target and approved digests. A fresh PASS is required. The workload runs from a verified file descriptor. Any failed check denies execution.

WHAT WE BUILT

The controller connects to an AlmaLinux 10 EC2 node through SSM, with no inbound ports.

The agent cannot contact the executor. The dispatcher verifies approval, then checks attestation and exact bytes before execution.



ALLOWED

Write one request file to the outbox.

BLOCKED

Read the outbox,
use the network,
call the executor,
or access signer keys,
receipts, and the MCP token.

nono: >..

LOCK 1

Agent Confinement

The agent **can only write a request file to the outbox**. The watcher independently computes the request ID, digests, and policy version.

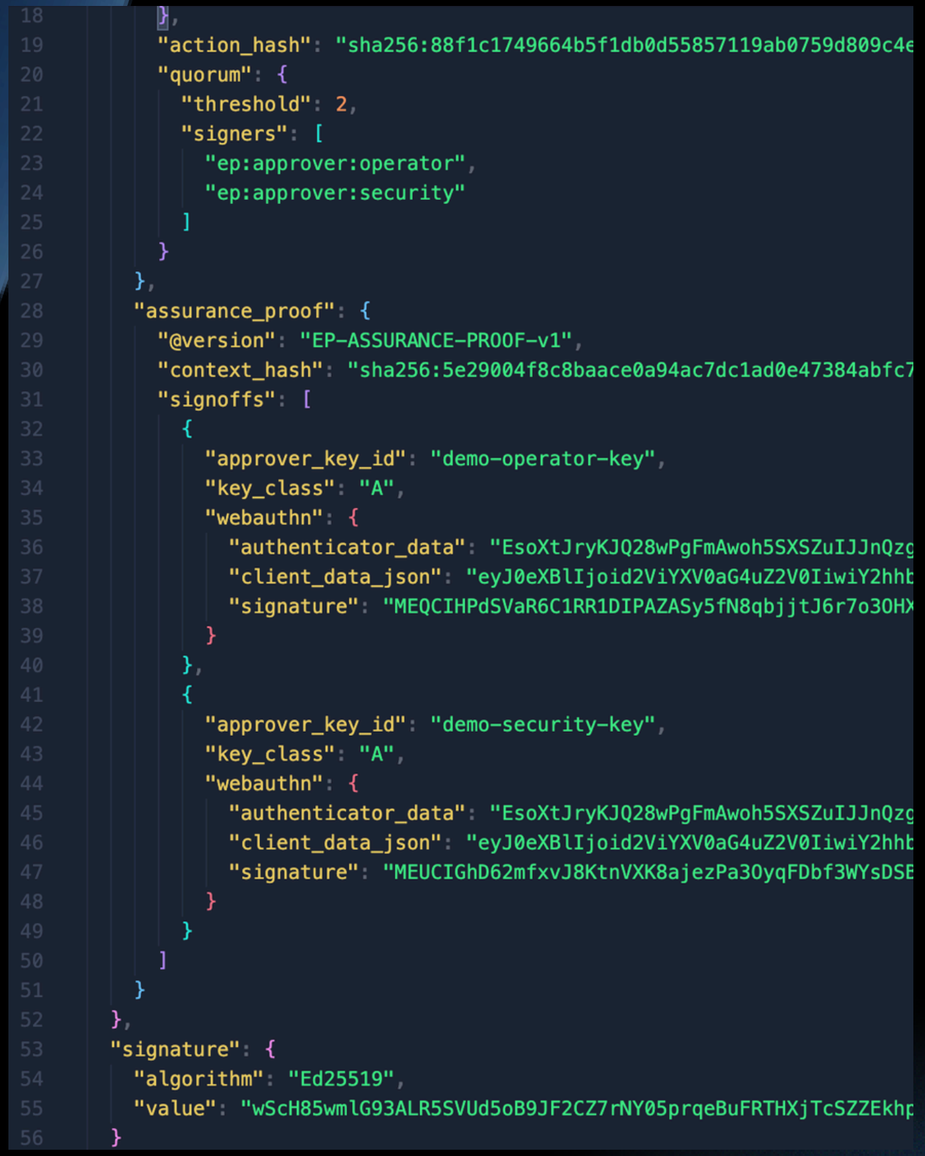
Nono is a sandbox that:

- enforces rules at the OS level
- Seatbelt w/MacOS, Landlock with Linux
- returns a JSON w/program access
- removes critical information
- isolates process
- ingrained reasonings to allow or prevent a program from a path

What we built with Nono:

- **nono_profile.py**
  - our specific sandbox policies (will be mentioned later)
- **submit_request.py**
  - helper that writes a valid request into the outbox
- **outbox_watcher.py**
  - reads outbox, rebuilds request with unique hashes and ids
- **handoff_confinement.py**
  - our check tests that tests our policies alongside nonos protocols
- **sandbox_check.mjs**
  - utilizes nono why to confirm the agent cannot read controller state, will refuse to run otherwise.
- experiments and tests for full end to end pipeline

LOCK 2: EMILIA PROTOCOL



EMILIA requires 2 of 3 signatures on a receipt for the exact action and target.

- why 2 of 3?
  - 1:3, one approve can pass without a second check
  - 3:3 any one approver can block everything

The dispatcher verifies the receipt, then consumes it once.

- rebuilds the action from the request
- hands of the receipt to EMILIA gate
  - checks: is receipt present?
  - is signed by an issuer?
  - less than 15 minutes old?
  - 2 of 3 signature approval
  - id used before?

Missing approval, changed action, expiry, or replay stops the run.

Currently, our approvers are keys, not real people. Our next steps include having human or AI approvers.

LOCK 3: KEYLIME ATTESTATION



Attestation Requirements

A Keylime PASS for the intended agent UUID must be no more than 30 seconds old.

Workload and input bytes must match the approved digests. Execution uses verified file descriptors.

Demo stack: Keylime 7.14.1, swtpm 0.9.0, AlmaLinux 10, EC2 t3.small, and SSM with no inbound ports.

3 of 3 Cases Pass

1. **Fresh attestation: exact workload runs.**
2. **Wrong target digest: denied before execution.**
3. **Keylime unavailable: denied before execution.**

The 30-second freshness limit leaves a window between node failure and expiration.

Anatomy of a real receipt: approval is bound to one exact action

1 · CANONICAL ACTION (COMPUTED BY THE WATCHER)

action_type	workload.execute
operation	checksum.sha256
target	aws-keylime-demo-01
artifact	sha256:b709d16d…7a12
input	sha256:79716dd5…a4b3
occurrence	28a79506-…-411fb96f2650
policy	demo-2.1

→

2 · ACTION HASH

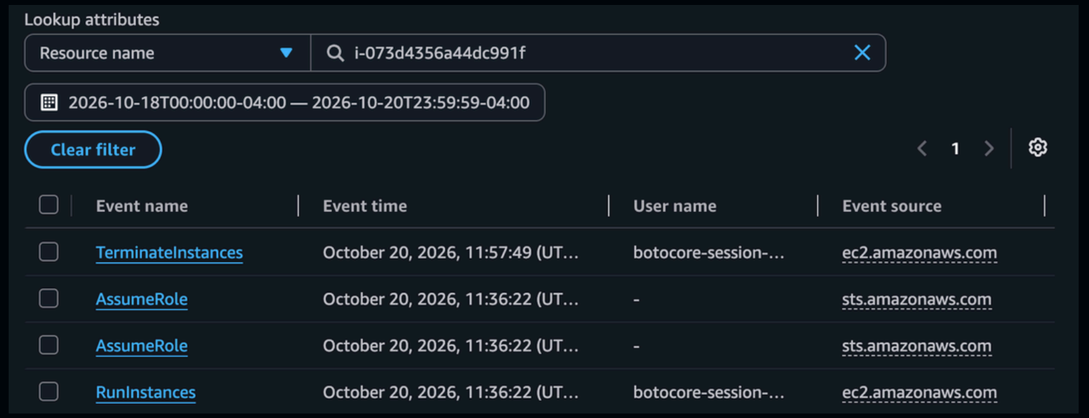
sha256:fd48857e…d7ccec

3 · QUORUM: 2 OF 3 APPROVERS

- ✓ ep:approver:operator signed
- ✓ ep:approver:security signed
- – third approver not needed

4 · RECEIPT SIGNATURE

Ed25519 · EP-RECEIPT-v1



Change any field and the hash no longer matches: refused as *action_hash_mismatch*.

Present it twice and the dispatcher's durable store refuses it: *replay_refused*, even after a restart.

One signature is not a receipt: the request stays pending.

Source: verified_receipts[0] in results/demo2-authorization.json (digests shortened; signer keys are demo keys on one laptop)

Every recorded scenario behaved as designed

LOCK 1 · NONO

9/9

escape paths from the sandbox blocked or allowed as expected

- *outbox write allowed*
- *outbox read blocked*
- *inbox write blocked*
- *inbox read allowed*
- *network block*
- *MCP block*
- *reciept store*
- *signer key*
- *MCP token*

`make integration-nono`

LOCK 2 · EMILIA

11/11

authorization cases: quorum, binding, replay, expiry

- *missing receipt*
- *one signer, dupe signer*
- *untrusted signer*
- *two signer quorum*
- *target binding*
- *exact action*
- *replay, restart*
- *expired, one signer expired*

`results/demo2-authorization.json`

LOCK 3 · KEYLIME

3/3

attestation cases, including fail-closed when Keylime is down

- *fresh attestation*
- *wrong target*
- *keylime unavailable*

`results/demo2-attestation.json`

ALL THREE · AWS

7/7

scenarios in one continuous end-to-end run, 1 min 37 s

- *no receipt*
- *one signature*
- *changed action*
- *exact action*
- *used receipt replay*
- *agent stopped*
- *agent recovered*

***end to end scenarios**

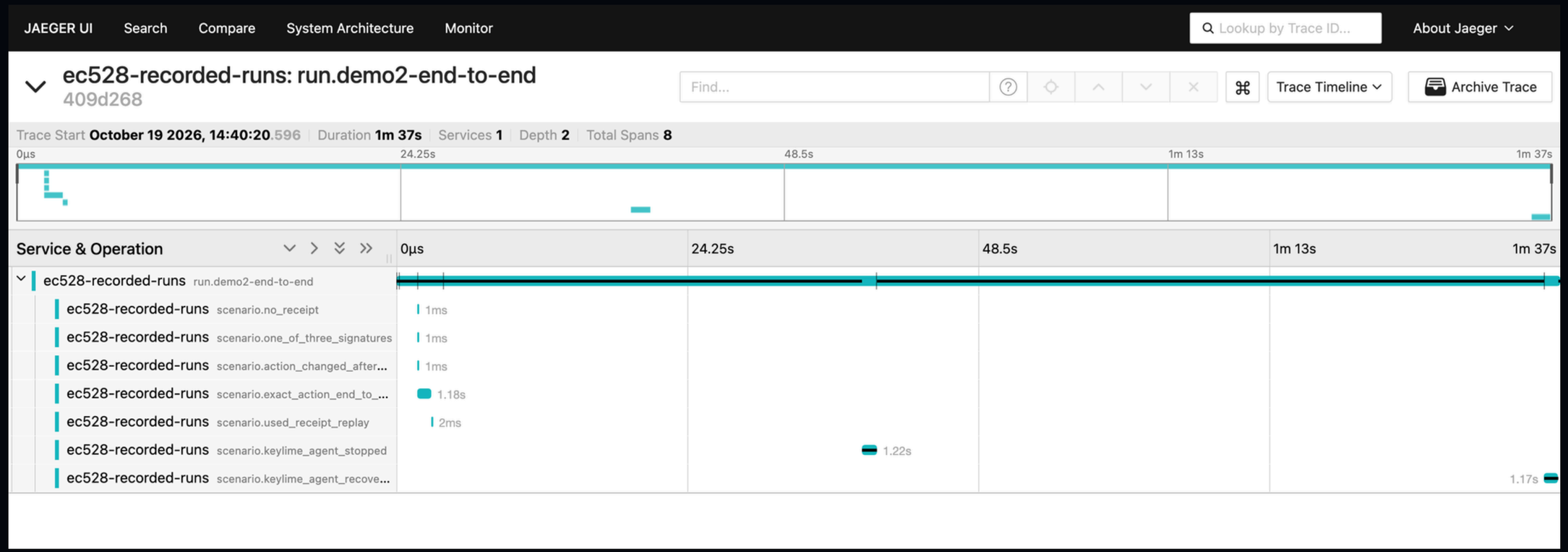
`results/demo2-end-to-end.json`

Recorded 2026-10-19 at commit 7de165c. swtpm, one self-checking node and three demo keys on one laptop: protocol proof, not hardware trust.

What stops each attempt we tested

THE AGENT OR ATTACKER TRIES TO…	STOPPED BY	RECORDED OUTCOME
Call the executor or Gate directly	nono	blocked, no network · `integration-nono`
Read signer keys or the receipt store	nono	blocked · `integration-nono`
Run with no approval, or only one	EMILIA quorum	HTTP 428, pending · `end-to-end`
Change the action after approval	EMILIA action hash	action_hash_mismatch · `end-to-end`
Reuse a receipt, even after a restart	Durable receipt store	replay_refused · `authorization`
Run on the wrong machine	Keylime target binding	denied · `attestation`
Run while attestation is unavailable	Keylime, fails closed	HTTP 500, did not run · `end-to-end`

Tracing the Full Run in Jaeger



One trace shows the 97-second recorded run. Four refusals ended at the receipt gate in 1–2 ms. Three requests reached Keylime on AWS and took about 1.2 s each. The gaps reflect waiting for attestation to expire, then restarting and re-enrolling the agent.

DEMO 2 LIMITS

- Approvals need separate devices
- Attestation: verifier needs to be run on a different machine or service
- SoftwareTPM → NitroTPM for hardware

The controls worked in the recorded run. The tests prove that the decision flow works, but it does not prove that the system would remain trustworthy if the machine was compromised.

swtpm provides no hardware-backed identity. The verifier runs on the node it checks, and three keys on one laptop are not independent approvers. Our next steps would be to approve, on different devices, so that keys do not remain on 1 device.

swtpm → NitroTPM for supported hardware backed, which is a manual implement on AWS with requirements.

NEXT STEPS



01

Authorization

Met: exact action, target binding, replay denial.



02

Keylime Attestation

Partial: fresh PASS works. IMA has been tested.



03

Quorum Bootstrap

Next: NitroTPM, off-node verifier, protected bootstrap.



04

Platform & Next Steps

Next: separate approvers and timing trials.

EC528 DEMO 2

THANK YOU

Mentor

Charles Munson

Institution

MIT Lincoln Laboratory

Source

commit 7de165c